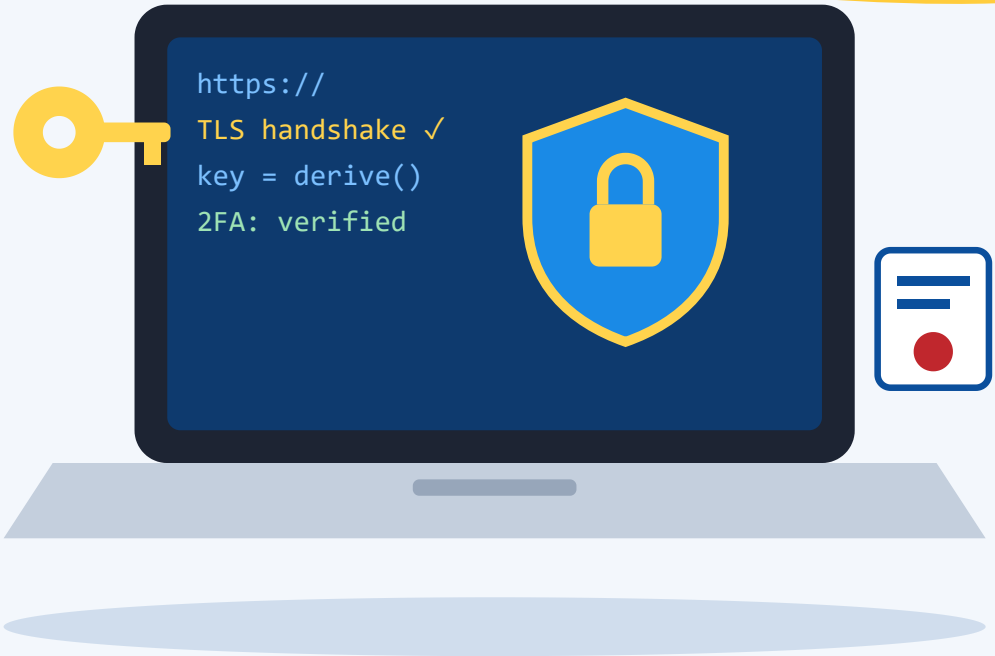
مادة البرمجة والذكاء الاصطناعي • الصف الثاني البكالوريا

سلسلة

{ عبد الناصر }
في البرمجة



إعداد
المهندس / أحمد عبد الناصر

01017865860

نظرة عامة على الوحدة

الفكرة العامة للوحدة

الأمان عبر الإنترنت لا يأتي من تقنية واحدة. نبدأ بحماية **الاتصال** نفسه (التشفير والمصادقة)، ثم نحمي **الشبكة** كلها (طبقات دفاع متعددة)، ثم نتعلم كيف **نستجيب** عندما يقع حادث أمني وكيف نحدد أولويات المخاطر.

أهداف التعلم

الدرس 2-1: تقنيات التشفير والمصادقة

- شرح كيف تستخدم اتصالات HTTPS تقنيات مختلفة لحماية الاتصال.
- التمييز بين دور التشفير، والشهادات الرقمية، والمصادقة الثنائية، والتوقيعات الرقمية.
- تقييم طريقة مصادقة في سياق محدد، وتبرير الاختيار باستخدام متطلبات الأمان وإمكانية الوصول.

الدرس 2-2: تصميم أمان الشبكات

- شرح أدوار جدار الحماية، وVPN، وDMZ، وضوابط الأجهزة الطرفية.
- شرح لماذا يوفر الدفاع في العمق حماية أقوى من الاعتماد على إجراء أمني واحد.
- تقييم تصميم أمني لشبكة، وتبرير اختيار الضوابط المناسبة وفق الأصول والتهديدات.

الدرس 2-3: الاستجابة للحوادث وإدارة المخاطر

- شرح المراحل العامة للاستجابة للحوادث والغرض من كل مرحلة.
- استخدام التأثير والاحتمالية لتحديد أولويات المخاطر.
- تصميم استجابة مبررة لحادث أمني، وربط إجراءات الاستجابة بالضوابط الوقائية المناسبة.

خريطة الوحدة

1 حماية الاتصال
TLS ▪ HTTPS ▪ التشفير ▪ الشهادات ▪ 2FA ▪ التوقيع الرقمي

←

2 حماية الشبكة
جدار الحماية ▪ DMZ ▪ VPN ▪ الدفاع في العمق ▪ انعدام الثقة

←

3 الاستجابة والمخاطر
الحادث الأمني ▪ المراحل الست ▪ التأثير × الاحتمالية

نصيحة للمذاكرة

احفظ **المصطلحات** بتعريفها الدقيق، وافهم **"لماذا"** وراء كل تقنية، لأن أسئلة الامتحان من نوع "اشرح لماذا..." عليها 6 درجات وتحتاج ربط الفكرة بالأمان والكفاءة.

2-1 تقنيات التشفير والمصادقة

عندما تسجل الدخول إلى تطبيق مصرفي أو تشتري عبر الإنترنت أو تفتح موقعًا يستخدم **HTTPS**، تعمل عدة تقنيات لحماية الاتصال: يشفّر **TLS** البيانات أثناء انتقالها، ويتحقق المتصفح من شهادة الموقع واسم النطاق، وتتحقق الخدمة من هوية المستخدم قبل منحه حق الوصول. هذه الوسائل **تقلل** المخاطر، لكنها لا تعني أن محتوى الموقع موثوق أو أن الحماية مطلقة.

❓ السؤال الرئيسي

كيف تعمل تقنيات التشفير والمصادقة معًا للحفاظ على أمان الاتصال والخدمات عبر الإنترنت؟

1. كيف تعمل اتصالات HTTPS

HTTPS: بروتوكول HTTP منقول عبر اتصال TLS مؤمّن. يوفر TLS **سرية** البيانات و**سلامتها** أثناء النقل، ويساعد المتصفح على **التحقق من هوية الخادم** واسم النطاق.

مصافحة TLS: هي خطوات إنشاء الاتصال الآمن. تجري فيها المصادقة بالشهادة الرقمية واشتقاق مفاتيح الجلسة، ثم يُستخدم التشفير المتماثل لحماية بيانات الاتصال بكفاءة.

المرحلة	ما يحدث	آلية الحماية الأساسية
① **مصافحة TLS: التحقق من الشهادة**	يرسل الخادم شهادته الرقمية، ويتحقق المتصفح من صلاحيتها وسلسلة الثقة وملاءمتها لاسم الموقع.	التشفير بالمفتاح العام
② **مصافحة TLS: اشتقاق مفاتيح الجلسة**	يتفاوض الطرفان على أسرار مشتركة تُشتق منها مفاتيح الجلسة، باستخدام آليات مفتاح عام مناسبة لإصدار TLS ومجموعة التشفير.	التشفير بالمفتاح العام
③ **تبادل البيانات**	تُحمى بيانات الجلسة بالتشفير المتماثل وآليات سلامة البيانات.	التشفير المتماثل

🔑 القاعدة الذهبية في TLS

المفتاح العام ← للمصادقة والاتفاق الآمن على مفاتيح الجلسة (يشارك المفتاح بأمان).

التشفير المتماثل ← لحماية بيانات الجلسة بسرعة وكفاءة (يتبادل البيانات بسرعة).

ماذا يوفر HTTPS؟ وماذا لا يوفر؟

✓ يوفره اتصال HTTPS / TLS	✗ لا يضمنه
السرية: لا يستطيع طرف ثالث قراءة البيانات أثناء النقل.	أن يكون **محتوى الموقع** نفسه موثوقًا أو صادقًا.
السلامة: اكتشاف أي تلاعب بالبيانات أثناء النقل.	أن تكون **الحماية مطلقة**؛ هو يقلل المخاطر فقط.
التحقق من هوية الخادم واسم النطاق عبر الشهادة الرقمية.	هوية **المستخدم**؛ وهذه تتحقق منها الخدمة بالمصادقة (مثل 2FA).

تدفق الاتصال عبر HTTPS (الشكل 2.1.1)

خادم الويب (مع المفتاح الخاص)	المتصفح (العميل)

① مصافحة TLS — الشهادة الرقمية والمفتاح العام — الخادم ← المتصفح

يرسل الخادم شهادته، ويتحقق المتصفح من صلاحيتها وسلسلة الثقة وملاءمتها لاسم الموقع.

② مصافحة TLS — معاملات تبادل المفاتيح ↔

يتبادل الطرفان معاملات تبادل المفاتيح، ويشتق كل طرف مفتاح الجلسة لديه **دون إرسال المفتاح نفسه عبر الشبكة**.

③ تبادل البيانات — بيانات محمية بمفاتيح الجلسة ↔

تُحمى بيانات الجلسة بالتشفير المتماثل وآليات سلامة البيانات.

المفتاح العام: للمصادقة والاتفاق الآمن على مفاتيح الجلسة ▪ التشفير المتماثل: لحماية بيانات الجلسة بسرعة

مقارنة: التشفير المتماثل والتشفير بالمفتاح العام

وجه المقارنة	التشفير بالمفتاح العام (غير المتماثل)	التشفير المتماثل
المفاتيح	زوج من المفاتيح المرتبطة: مفتاح عام ومفتاح خاص	مفتاح جلسة مشترك بين الطرفين
الوظيفة في TLS	المصادقة والاتفاق الآمن على مفاتيح الجلسة (أثناء المصافحة)	حماية بيانات الجلسة (بعد المصافحة)
السرعة	أبطأ؛ لا يناسب تبادل كميات كبيرة من البيانات	سريع وفعّال لكميات البيانات الكبيرة
الخلاصة	يشارك المفتاح بأمان	يتبادل البيانات بسرعة

⚠ خطأ شائع

"يتبادل اتصال HTTPS جميع البيانات باستخدام التشفير بالمفتاح العام" ← **عبارة خاطئة**؛ لأن تبادل جميع البيانات بالمفتاح العام سيكون بطيئًا، لذا يُستخدم **التشفير المتماثل** لتبادل البيانات بعد المصافحة.

سؤال بنمط الامتحان [6 درجات]

اشرح لماذا يستخدم TLS آليات المفتاح العام للمصادقة والاتفاق الآمن على مفاتيح الجلسة، ثم يستخدم التشفير المتماثل لحماية بيانات الجلسة. (استعن بـ: الأمان والكفاءة)

✓ آليات المفتاح العام تسمح بالتحقق من هوية الخادم عبر الشهادة الرقمية، وبالاتفاق على مفاتيح الجلسة دون إرسال المفتاح نفسه عبر الشبكة، فتحقق **الأمان**. لكنها بطيئة، لذلك بعد إنشاء مفاتيح الجلسة يُستخدم التشفير المتماثل لأنه سريع وفعّال في حماية الكميات الكبيرة من البيانات، فيتحقق **الأمان والكفاءة** معًا.

2. استخدام المصادقة في الخدمات الفعلية

المصادقة الثنائية (2FA – Two-Factor Authentication): استخدام عاملين مستقلين من فئتين مختلفتين لإثبات الهوية.

المصادقة متعددة العوامل (MFA – Multi-Factor Authentication): استخدام عاملين أو أكثر من فئات مختلفة، مثل المعرفة والحيازة والسمات الحيوية.

فئات عوامل المصادقة

الفئة	المعنى	أمثلة
المعرفة	شيء **تعرفه**	كلمة المرور، الرقم السري، السؤال السري
الحيازة	شيء **تملكه**	الهاتف (كلمة مرور لمرة واحدة، رسائل SMS، إشعار التطبيق)، بطاقة دخول، بطاقة IC، بطاقة الائتمان، مفتاح أمان
السمات الحيوية	شيء **تكونه** (من جسمك)	بصمة الإصبع، التعرف على الوجه

لماذا المصادقة الثنائية مهمة؟

يقلل استخدام عامل مستقل ثانٍ احتمال الدخول غير المصرح به إذا كُشفت كلمة المرور. فبعد إدخال كلمة المرور قد يُطلب رمز من تطبيق مصادقة أو جهاز يملكه المستخدم؛ وعندئذ **لا تكفي معرفة كلمة المرور وحدها للدخول**.

أمثلة على المصادقة في خدمات متنوعة

الخدمة	المصادقة المستخدمة
الخدمات المصرفية عبر الإنترنت	كلمة المرور (المعرفة) + كلمة المرور لمرة واحدة (الحيازة)
تسجيل الدخول إلى وسائل التواصل الاجتماعي	كلمة المرور (المعرفة) + المصادقة عبر الرسائل القصيرة SMS (الحيازة)
الدخول إلى مبنى مؤمَّن	بطاقة دخول (الحيازة) + بصمة إصبع (السمات الحيوية)
التسوق الإلكتروني	كلمة المرور (المعرفة) + التحقق من هوية بطاقة الائتمان (الحيازة)

> ⚠ **انتبه — ليست كل خطوتين مصادقةً ثنائية!**
>
> تعيين **كلمتي مرور** أو **كلمة مرور + سؤال سري** ليس مصادقة ثنائية؛ لأن كلا العاملين من فئة **المعرفة** نفسها. هذا يُسمى مصادقة متعددة الخطوات باستخدام نفس العامل، وليس عاملين مختلفين.

> 💭 **توقف وفكّر**
>
> إذا تسربت كلمة المرور، لماذا يمكن لعامل ثانٍ يُرسل إلى الهاتف أن يظل يحمي الحساب؟
>
> ✓ لأن المهاجم يعرف كلمة المرور فقط (المعرفة) لكنه لا يملك هاتف المستخدم (الحيازة)، فلا يستطيع الحصول على الرمز وإكمال تسجيل الدخول.

3. تركيبات تقنيات الأمان

يتحقق الاتصال والخدمات الآمنة ليس من خلال تقنية واحدة، بل من خلال **الجمع بين عدة تقنيات أمان**.

التقنية	التأثير (ماذا تفعل؟)
التشفير (بالمفتاح المتناظر / بالمفتاح العام)	يمنع قراءة محتوى الاتصال من قِبل أطراف ثالثة
التوقيع الرقمي	يدعم التحقق من سلامة البيانات وهوية الموقِّع، ويوفر دليلًا يدعم عدم التنصل عندما يتطلب النظام ذلك
الشهادة الرقمية	تساعد المتصفح على التحقق من هوية الخادم واسم النطاق الذي يتصل به
المصادقة الثنائية (2FA)	تقلل احتمال تسجيل الدخول غير المصرح به

مثال تطبيقي: شراء منتج عبر التسوق الإلكتروني

1. عندما تدخل إلى الموقع، يبدأ اتصال HTTPS، ويمنع **التشفير** قراءة محتوى الاتصال من قِبل أطراف ثالثة.
2. يتحقق المتصفح من **الشهادة الرقمية** واسم النطاق للتأكد من هوية الخادم الذي يتصل به.
3. عند تسجيل الدخول، تقلل **المصادقة الثنائية (2FA)** احتمال الدخول غير المصرح به باستخدام عاملين مستقلين.
4. أثناء إرسال تفاصيل الطلب، يحمي **TLS** سرية البيانات وسلامتها أثناء النقل، ويُستخدم **التوقيع الرقمي** لإثبات التوقيع على بيانات أو رسائل محددة عندما يتطلب النظام ذلك.

يتيح الجمع بين تقنيات الحماية تقليل مخاطر عدة تهديدات، مثل **التنصت والتلاعب وانتحال الهوية والدخول غير المصرح به**، من دون افتراض أن أي تقنية تمنع الخطر منعًا مطلقًا.

ربط التهديد بالتقنية المناسبة

التهديد	التقنية التي تعالجه أساسًا
اعتراض محتوى الاتصال (التنصت)	**التشفير**
تعديل البيانات أثناء الاتصال (التلاعب)	**التوقيع الرقمي**
توجيه المستخدم إلى موقع مزيف (انتحال هوية الخادم)	**الشهادة الرقمية**
تسرب كلمة المرور ومحاولة الدخول غير المصرح به	**المصادقة الثنائية (2FA)**

> ☆ **الفكرة الرئيسة**
>
> لا يأتي الأمان عبر الإنترنت من تقنية واحدة، بل من الجمع بين **التشفير والشهادات والتوقيعات والمصادقة** بحيث تتم معالجة تهديدات كثيرة في آن واحد.

مصطلحات أساسية للدرس 1-2

HTTPS
نظام لإجراء اتصالات الويب بأمان (التشفير، واكتشاف التلاعب، والتحقق من الطرف المقابل).

مصافحة TLS
خطوات إنشاء الاتصال الآمن: المصادقة بالشهادة واشتقاق مفاتيح الجلسة.

التشفير
يحافظ على خصوصية المحتوى؛ يمنع قراءته من أطراف ثالثة.

التشفير بالمفتاح العام
يشارك المفتاح بأمان؛ يستخدم زوجًا من المفاتيح: عام وخاص.

التشفير المتماثل
يتبادل البيانات بسرعة باستخدام مفتاح الجلسة المشترك.

الشهادة الرقمية
تساعد المتصفح على التحقق من هوية الخادم وارتباط الشهادة باسم النطاق.

التوقيع الرقمي
يكتشف التلاعب وانتحال الشخصية، ويوفر دليلًا يدعم عدم التنصل.

عدم التنصل
عدم قدرة الموقِّع على إنكار أنه أرسل أو وقّع رسالة/بيانات.

المصادقة الثنائية (2FA)
عاملان مستقلان من فئتين مختلفتين؛ تقلل احتمال الدخول غير المصرح به.

المصادقة متعددة العوامل (MFA)
عاملان أو أكثر من فئات مختلفة: المعرفة، الحيازة، السمات الحيوية.

✎ مثال محلول

(1) ضع علامة (○) أمام العبارة الصحيحة وعلامة (×) أمام العبارة الخاطئة:

العبارة	الحكم	التعليل
أ. يستخدم اتصال HTTPS كلًّا من التشفير بالمفتاح العام والتشفير المتماثل.	○	المفتاح العام للمصادقة والاتفاق على المفاتيح، ثم المتماثل للبيانات.
ب. يتبادل اتصال HTTPS جميع البيانات باستخدام التشفير بالمفتاح العام.	×	سيكون بطيئًا؛ لذا يُستخدم المتماثل لتبادل البيانات.
ج. المصادقة الثنائية تستخدم عاملين مستقلين من فئتين مختلفتين لإثبات الهوية.	○	تعريف صحيح للمصادقة الثنائية.
د. من أمثلة المصادقة الثنائية: تعيين كلمتي مرور.	×	كلتاهما من عامل "المعرفة"؛ فهي متعددة الخطوات بنفس العامل.

(2) طابق كل تهديد بأنسب تقنية أمان:

المطلوب	التقنية
أ. أريد منع قراءة محتوى الاتصال من قِبل أطراف ثالثة.	**التشفير**
ب. أريد التحقق من أن رسالة موقّعة لم يتم تعديلها، وأنها صدرت عن الموقِّع المزعوم.	**التوقيع الرقمي**
ج. أريد التحقق من أن الطرف المقابل في الاتصال حقيقي.	**الشهادة الرقمية**

تدريبات وتمارين الدرس 1-2 (مع الإجابات النموذجية)

1. ما دور الشهادة الرقمية وآليات المفتاح العام في بدء اتصال TLS آمن؟

✓ الشهادة الرقمية تُمكّن المتصفح من التحقق من هوية الخادم وارتباطها باسم النطاق، وآليات المفتاح العام تُستخدم للمصادقة والاتفاق الآمن على مفاتيح الجلسة.

2. ما نوع التشفير المستخدم لحماية بيانات الجلسة بعد إنشاء مفاتيحها؟

✓ التشفير المتماثل.

3. استخرج من الفقرة ثلاث خطوات مرتبة لإنشاء اتصال HTTPS آمن.

✓ ① يرسل الخادم شهادته الرقمية ويتحقق المتصفح من صلاحيتها وملاءمتها لاسم الموقع. ② يتفق الطرفان على إعدادات الحماية وتُشتق مفاتيح الجلسة. ③ تُحمى بيانات الجلسة بالتشفير المتماثل وآليات سلامة البيانات.

4. اشرح بإيجاز سبب استخدام مفاتيح جلسة متماثلة لحماية كميات البيانات المتبادلة بعد المصافحة.

✓ لأن التشفير المتماثل سريع وفعّال في حماية الكميات الكبيرة من البيانات، بينما التشفير بالمفتاح العام بطيء.

5. لكل خدمة، بيّن أي مجموعة من عوامل المصادقة تُستخدم: (أ) المعرفة + الحيازة (ب) المعرفة + السمات الحيوية (ج) السمات الحيوية + الحيازة

الخدمة	المجموعة
كلمة مرور + كلمة مرور لمرة واحدة	**(أ) المعرفة + الحيازة**
كلمة مرور + مصادقة ببصمة الإصبع	**(ب) المعرفة + السمات الحيوية**
كلمة مرور + مصادقة عبر الرسائل القصيرة SMS	**(أ) المعرفة + الحيازة**
التعرف على الوجه + بطاقة IC	**(ج) السمات الحيوية + الحيازة**

6. لكل تهديد، بيّن التقنية المستخدمة أساسًا لمعالجته: (أ) التشفير (ب) التوقيع الرقمي (ج) الشهادة الرقمية (د) المصادقة الثنائية

✓ تسرب كلمة مرور ودخول غير مصرح به ← (د) ▪ تعديل البيانات أثناء الاتصال ← (ب) ▪ توجيه المستخدم إلى موقع مزيف ← (ج) ▪ اعتراض المحتوى من طرف ثالث ← (أ)

7. اختر الخيار الذي لا يمثل وصفًا مناسبًا لتركيبات تقنيات الأمان:

أ التشفير يمنع قراءة محتوى الاتصال من أطراف ثالثة.
ب التوقيعات الرقمية تقنية تُحسّن سرعة الاتصال.
ج الشهادات الرقمية للتحقق من أن الطرف المقابل حقيقي.
د الجمع بين عدة تقنيات يعالج تهديدات متنوعة.

✓ الإجابة (ب)؛ التوقيع الرقمي يتحقق من سلامة البيانات وهوية الموقّع ولا علاقة له بسرعة الاتصال.

8. اختر الخيار الذي لا يمثل مثالًا مناسبًا للمصادقة الثنائية:

أ كلمة مرور + إشعار على الهاتف الذكي
ب كلمة مرور + سؤال سري
ج بصمة الإصبع + بطاقة IC
د كلمة مرور + رسائل SMS

✓ الإجابة (ب)؛ لأن كلمة المرور والسؤال السري كلاهما من فئة المعرفة.

طبّق ما تعلمته — متجر إلكتروني صغير

تقنيتان مناسبتان: HTTPS/TLS لتشفير بيانات الدفع وتسجيل الدخول أثناء النقل، والمصادقة الثنائية لحماية حسابات العملاء. **تهديد قد يظل قائمًا:** التصيد الاحتيالي (خداع المستخدم بموقع مزيف أو رسالة)، أو ثغرات في الخادم نفسه.

امتحان الدرس 1-2: تقنيات التشفير والمصادقة

20 درجة

الاسم: ..... الفصل: ..... الزمن: 30 دقيقة الدرجة: ..... / 20

أولًا: اختر الإجابة الصحيحة

5 درجات

1. يتكون HTTPS من بروتوكول HTTP منقول عبر اتصال:

أ VPN ب TLS ج DMZ د 2FA

2. في مرحلة تبادل البيانات بعد المصافحة تُحمى البيانات باستخدام:

أ التشفير بالمفتاح العام ب الشهادة الرقمية

ج التشفير المتماثل د التوقيع الرقمي

3. التقنية التي تساعد المتصفح على التحقق من هوية الخادم واسم النطاق:

أ الشهادة الرقمية ب التشفير المتماثل ج المصادقة الثنائية د جدار الحماية

4. كلمة المرور + التحقق من بطاقة الائتمان في التسوق الإلكتروني تمثل:

أ المعرفة + الحيازة ب المعرفة + السمات الحيوية

ج الحيازة + السمات الحيوية د المعرفة + المعرفة

5. أي مما يلي يُعد مصادقة ثنائية صحيحة؟

أ كلمتا مرور ب كلمة مرور + سؤال سري

ج بطاقة دخول + بصمة إصبع د رقم سري + تاريخ الميلاد

ثانيًا: ضع علامة (✓) أو علامة (✗)

5 درجات

6. يضمن اتصال HTTPS أن محتوى الموقع موثوق وأن الحماية مطلقة. ( )
7. في مصافحة TLS يشتق كل طرف مفتاح الجلسة دون إرسال المفتاح نفسه عبر الشبكة. ( )
8. التوقيع الرقمي هو التقنية التي تمنع قراءة محتوى الاتصال من أطراف ثالثة. ( )
9. المصادقة متعددة العوامل (MFA) تستخدم عاملين أو أكثر من فئات مختلفة. ( )
10. الجمع بين عدة تقنيات أمان يقلل مخاطر تهديدات متعددة في آن واحد. ( )

ثالثًا: أكمل العبارات التالية

4 درجات

11. يتحقق المتصفح أثناء مصافحة TLS من صلاحية الشهادة و ..... وملاءمتها لاسم الموقع.
12. فئات عوامل المصادقة الثلاث هي: المعرفة و ..... و .....
13. التقنية التي توفر دليلًا يدعم عدم التنصل هي .....
14. يُستخدم التشفير المتماثل لحماية بيانات الجلسة لأنه .....

رابعًا: أجب عما يأتي

6 درجات (3 لكل سؤال)

15. اذكر المراحل الثلاث لإنشاء اتصال HTTPS آمن، وآلية الحماية الأساسية في كل مرحلة.

16. متجر إلكتروني صغير يريد تأمين تسجيل دخول العملاء والدفع: اقترح تقنيتين وبيّن دور كل منهما، واذكر تهديدًا قد يظل قائمًا.

2-2 تصميم أمان الشبكات

في الدرس 2-1 تعلمت كيف تحمي تقنيات التشفير والمصادقة الاتصال والحسابات. في هذا الدرس تتوسع الحماية إلى **تصميم الشبكة نفسها**. تحتفظ شبكات المؤسسات ببيانات وخدمات مهمة قد يحاول مهاجم الوصول إليها، ولا تكفي وسيلة حماية واحدة؛ فإذا فشلت قد تتعرض موارد أخرى للخطر. لذلك يُستخدم **الدفاع في العمق**، فتعمل طبقات متعددة على تقليل احتمال الاختراق والحد من أثره.

❓ السؤال الرئيسي

كيف يمكن لمؤسسة أن تصمم شبكتها بحيث، حتى لو تم اختراق أحد الدفاعات، يظل النظام محميًا؟

1. دور جدران الحماية

جدار الحماية (Firewall): نظام أو برنامج يراقب حركة مرور الشبكة ويسمح بها أو يمنعها وفق قواعد أمنية محددة مسبقًا. وقد يوجد عند حدود الشبكة أو بين أجزائها أو على جهاز مضيف.

📌 مثال

السماح بالوصول إلى خادم الويب، مع منع الوصول الخارجي المباشر إلى قاعدة البيانات.

2. الشبكة الافتراضية الخاصة (VPN)

الشبكة الافتراضية الخاصة (VPN – Virtual Private Network): اتصال أو شبكة منطقية خاصة عبر شبكة عامة مثل الإنترنت، تستخدم عادةً التشفير وتقنيات النفق لحماية البيانات بين الطرفين.

الاستخدامات الرئيسية لـ VPN

الاستخدام	الشرح
① العمل عن بُعد	الاتصال بأمان بشبكة المؤسسة من المنزل أو أثناء التنقل.
② ربط الفروع	ربط المكاتب في مواقع مختلفة بأمان.

نظرًا لأن محتوى الاتصال **يُشفَّر** عند استخدام VPN، تقل مخاطر **التنصت** حتى عند استخدام شبكة Wi-Fi عامة.

⚠ ما ليس من وظائف VPN

VPN **لا** يقوم بالحذف التلقائي للملفات المصابة بالفيروسات؛ هذه وظيفة برامج مكافحة الفيروسات على الأجهزة الطرفية. وظيفة VPN هي إنشاء نفق مشفّر لحماية البيانات أثناء النقل.

جدار الحماية
يسمح بالاتصال أو يمنعه عند نقطة دخول/خروج الشبكة استنادًا إلى قواعد محددة مسبقًا.

VPN
خط خاص افتراضي مشفّر عبر الإنترنت للاتصال الآمن من موقع بعيد.

3. المنطقة المعزولة (DMZ – Demilitarized Zone)

المنطقة المعزولة (DMZ): منطقة تُوضع فيها الخوادم المعرَّضة للشبكة الخارجية (خوادم الويب، خوادم البريد، إلخ) بشكل منفصل عن الشبكة الداخلية.

يساعد فصل الخوادم العامة في منطقة معزولة على **تقليل احتمال وصول الهجوم منها إلى الشبكة الداخلية** إذا تعرض أحدها للاختراق.

تكوين شبكة المنطقة المعزولة (الشكل 2.2.1)



إذا تمت مهاجمة خادم عام، فإن الشبكة الداخلية لا تزال محمية.

توقف وفكّر: لماذا يكون وضع خادم ويب عام في DMZ أكثر أمانًا من وضعه داخل الشبكة الداخلية؟

✓ لأن خادم الويب معرَّض للإنترنت وبالتالي للهجمات؛ فإذا كان داخل الشبكة الداخلية واخُترق، يصل المهاجم مباشرة إلى البيانات السرية. أما في DMZ فهو مفصول بجدار حماية، فيبقى الضرر محصورًا ولا يصل بسهولة إلى الشبكة الداخلية.

خطأ شائع

"المنطقة المعزولة نظام يعرّض جميع الخوادم للخارج" ← **خطأ**؛ فهي منطقة توضع فيها الخوادم **المواجهة للجمهور فقط** بشكل منفصل عن الشبكة الداخلية. والسبب الأنسب لاستخدامها: **منع الضرر عن الشبكة الداخلية حتى لو تعرض خادم مواجه للجمهور للهجوم**، وليس تحسين سرعة الاتصال أو إزالة الفيروسات.

تلميح

ضع الخادم العام في المنطقة المعزولة لتقليل احتمال وصول المهاجم إلى الشبكة الداخلية إذا اخُترق الخادم، ولا تعتمد على العزل وحده.

فكّر كمهندس — شركة لديها موقع عام وموظفون عن بُعد وبيانات عملاء سرية

الأصول وتهديداتها: الموقع العام ← الاختراق من الإنترنت ▪ الموظفون عن بُعد ← التنصت على Wi-Fi العامة ▪ بيانات العملاء ← التسرب. **الربط بالطبقات:** الموقع ← وضع الخوادم (DMZ) ▪ الموظفون ← مسار الاتصال (VPN) ▪ البيانات ← مدخل الشبكة (جدار الحماية) والأجهزة الطرفية. **القرار:** التصميم متعدد الطبقات + التحقق من كل عملية وصول أكثر أمانًا من جدار حماية واحد.

4. الدفاع في العمق (Defense in Depth)

الدفاع في العمق: استخدام طبقات متعددة من الضوابط الأمنية، بحيث تساعد طبقات أخرى على تقليل الخطر والحد من أثر الاختراق إذا فشلت إحدى الطبقات. **"إذا فشلت طبقة حماية، تبقى طبقات أخرى تقلل الخطر"**

الطبقة	أمثلة على الإجراءات
الطبقة 1: مدخل الشبكة	منع الاتصال غير المصرح به باستخدام **جدار الحماية**
الطبقة 2: مسار الاتصال	تشفير الاتصال باستخدام **الشبكة الافتراضية الخاصة (VPN)**
الطبقة 3: وضع الخوادم	فصل الخوادم المواجهة للجمهور عن الشبكة الداخلية باستخدام **المنطقة المعزولة (DMZ)**
الطبقة 4: الأجهزة الطرفية	تثبيت **برنامج مكافحة الفيروسات** والحفاظ على **تحديث نظام التشغيل**

5. مفهوم نهج انعدام الثقة (Zero Trust)

نهج انعدام الثقة: نهج أمني لا يمنح الثقة تلقائيًا لمستخدم أو جهاز لمجرد وجوده داخل الشبكة أو ملكيته للمؤسسة. تُفحص **الهوية والصلاحيات والسياق** عند طلب الوصول إلى الموارد وفق سياسة المؤسسة. **"تحقق من كل عملية وصول"**

صُمم أمان الشبكات التقليدي حول حماية **المحيط الأمني** على فرضية أن "داخل شبكة المؤسسة آمن وخارجها خطر". ومع انتشار الخدمات السحابية والعمل عن بُعد أصبحت الحدود بين "الداخل" و"الخارج" غير واضحة، وأصبحت حماية المحيط وحدها غير كافية.

مقارنة: الأمان التقليدي ونهج انعدام الثقة (الشكل 2.2.2)

وجه المقارنة	الأمان التقليدي	نهج انعدام الثقة (الثقة الصفرية)
الفكرة	الداخل موثوق (بدون تحقق)، والخارج غير موثوق	لا يوجد حاجز داخلي/خارجي
وسيلة الحماية	جدار حماية عند المحيط الأمني	التحقق من كل عملية وصول (الهوية والصلاحيات والسياق)
الثقة	تُمنح تلقائيًا لمن هو داخل الشبكة	لا تُمنح تلقائيًا لأي مستخدم أو جهاز
الملاءمة اليوم	غير كافية مع السحابة والعمل عن بُعد	مناسب لتلاشي الخط الفاصل بين الداخل والخارج

> ⭐ **الفكرة الرئيسة**
>
> يكون أمان الشبكة في أقوى حالاته عندما **تُكدَّس الإجراءات في طبقات متعددة (الدفاع في العمق)** و**لا يُمنح أي وصول ثقة تلقائيًا (نهج انعدام الثقة)**، بحيث يصبح من غير المرجح أن يؤدي خرق واحد إلى كشف النظام بأكمله.

> 🌍 **طبّق ما تعلمته — مستشفى ينقل السجلات إلى السحابة**
>
> **إجراءان:** ① مصادقة متعددة العوامل للأطباء والتحقق من كل عملية وصول وفق الهوية والصلاحيات (انعدام الثقة). ② الوصول من المنزل عبر VPN مشفّرة مع تحديث أجهزة الأطباء ومكافحة الفيروسات (الدفاع في العمق). **خطر قائم:** سرقة جهاز طبيب أو بيانات دخوله عبر التصيد الاحتيالي.

مصطلحات أساسية للدرس 2-2

جدار الحماية
يسمح بالاتصال أو يمنعه عند نقطة دخول/خروج الشبكة استنادًا إلى قواعد محددة مسبقًا.

الشبكة الافتراضية الخاصة (VPN)
اتصال منطقي خاص مشفّر عبر شبكة عامة باستخدام تقنيات النفق.

المنطقة المعزولة (DMZ)
منطقة للخوادم المواجهة للجمهور، منفصلة عن الشبكة الداخلية.

الدفاع في العمق
تكديس الإجراءات الأمنية في طبقات متعددة.

نهج انعدام الثقة
التحقق من كل عملية وصول؛ لا ثقة تلقائية.

المحيط الأمني
الحدود التقليدية التي تفترض أن "الداخل آمن"، والتي طمستها الخدمات السحابية والعمل عن بُعد.

✎ مثال محلول

(1) ضع علامة (○) أمام العبارة الصحيحة وعلامة (×) أمام العبارة الخاطئة:

العبارة	الحكم	التعليل
أ. يسمح جدار الحماية بالاتصال أو يمنعه استنادًا إلى قواعد محددة مسبقًا.	○	يتحكم جدار الحماية في الاتصال استنادًا إلى القواعد.
ب. يمكن أن يقلل استخدام VPN من مخاطر التنصت حتى على شبكة Wi-Fi عامة.	○	تشفّر VPN الاتصال، مما يقلل مخاطر التنصت.
ج. المنطقة المعزولة نظام يعرّض جميع الخوادم للخارج.	×	توضع فيها الخوادم المواجهة للجمهور فقط بشكل منفصل.
د. الدفاع في العمق هو مفهوم تكديس عدة إجراءات أمنية في طبقات متعددة.	○	تعريف صحيح للدفاع في العمق.

(2) طابق كل وصف بأنسب مصطلح:

الوصف	المصطلح
أ. تقنية تنشئ خطًا خاصًا افتراضيًا مشفرًا عبر الإنترنت للاتصال الآمن من موقع بعيد.	**الشبكة الافتراضية الخاصة (VPN)**
ب. منطقة تُوضع فيها الخوادم المعرَّضة للخارج بشكل منفصل عن الشبكة الداخلية.	**المنطقة المعزولة (DMZ)**
ج. نظام يسمح بالاتصال أو يمنعه استنادًا إلى قواعد محددة مسبقًا.	**جدار الحماية**

📝 سؤال بنمط الامتحان [6 درجات]

اشرح لماذا يحمي تكديس عدة إجراءات أمنية في طبقات (الدفاع في العمق) المؤسسة بشكل أفضل من الاعتماد على جدار الحماية وحده. (استعن بـ: ما يحدث إذا تم اختراق أحد الإجراءات)

✓ جدار الحماية وحده نقطة فشل واحدة؛ فإذا تم تجاوزه أو أُخطئ في ضبط قواعده يصل المهاجم إلى كل شيء. أما مع الدفاع في العمق فإذا اختُرقت طبقة تبقى طبقات أخرى: VPN تشفّر الاتصال، وDMZ تفصل الخوادم العامة عن الشبكة الداخلية، ومكافحة الفيروسات وتحديث النظام تحمي الأجهزة الطرفية؛ فيقل احتمال الاختراق ويُحدّ من أثره.

تدريبات وتمارين الدرس 2-2 (مع الإجابات النموذجية)

السؤال	الإجابة
1. ما المصطلح الذي يصف نظامًا أو برنامجًا يراقب حركة مرور الشبكة ويسمح بها أو يمنعها وفق قواعد أمنية؟	**جدار الحماية**
2. ما الاختصار الذي يصف اتصالًا منطقيًا خاصًا يحمي البيانات عبر شبكة عامة؟	**VPN (الشبكة الافتراضية الخاصة)**
3. ما الاختصار المكوّن من ثلاثة أحرف للمنطقة التي تُوضع فيها الخوادم المعرَّضة للخارج بشكل منفصل عن الشبكة الداخلية؟	**DMZ (المنطقة المعزولة)**
4. ما المصطلح الذي يُطلق على مفهوم تكديس عدة إجراءات أمنية؟	**الدفاع في العمق**

5. اختر الخيار الذي لا يمثل استخدامًا مناسبًا للشبكة الافتراضية الخاصة:

أ الاتصال بأمان من المنزل بشبكة المؤسسة
ب ربط المكاتب في مواقع مختلفة بأمان
ج الحذف التلقائي للملفات المصابة بالفيروسات
د تشفير محتوى الاتصال على شبكة Wi-Fi العامة

✓ الإجابة (ج).

6. لكل إجراء أمني، بيّن أي طبقة من طبقات الدفاع ينتمي إليها:

الإجراء	الطبقة
منع الاتصال غير المصرح به باستخدام جدار الحماية	**مدخل الشبكة**
تشفير الاتصال باستخدام الشبكة الافتراضية الخاصة	**مسار الاتصال**
تثبيت برنامج مكافحة الفيروسات	**الأجهزة الطرفية**
فصل الخوادم المواجهة للجمهور باستخدام DMZ	**وضع الخوادم**

7. املأ الفراغات: لحماية شبكة مؤسسة، تُستخدم طبقات متعددة. يراقب (أ) حركة الشبكة ويسمح بها أو يمنعها وفق قواعد. وتوضع الخوادم العامة في (ب) منفصلة عن الشبكة الداخلية. ويُحمى الاتصال البعيد عبر (ج). ويسمى استخدام طبقات متعددة من الضوابط الأمنية (د).

✓ (أ) جدار الحماية ▪ (ب) المنطقة المعزولة DMZ ▪ (ج) الشبكة الافتراضية الخاصة VPN ▪ (د) الدفاع في العمق

8. اختر السبب الأنسب لاستخدام منطقة معزولة (DMZ):

أ لتحسين سرعة الاتصال. ب لتعريض جميع الخوادم للخارج.
ج لمنع الضرر عن الشبكة الداخلية حتى لو تعرض خادم مواجه للجمهور للهجوم. د للكشف عن الفيروسات وإزالتها تلقائيًا.

✓ الإجابة (ج).

9. اختر الخيار الذي يصف مفهوم نهج انعدام الثقة بأنسب طريقة:

أ الوصول من داخل شبكة المؤسسة آمن، لذا التحقق غير ضروري. ب جدار الحماية وحده كافٍ.
ج لا تُمنح الثقة تلقائيًا، ويُتحقق من كل طلب وصول وفق الهوية والصلاحيات والسياق. د يحتاج فقط الوصول من الخارج إلى المراقبة.

✓ الإجابة (ج).

امتحان الدرس 2-2: تصميم أمان الشبكات

20 درجة

الاسم: ..... الفصل: ..... الزمن: 30 دقيقة الدرجة: ..... / 20

أولًا: اختر الإجابة الصحيحة

5 درجات

1. نظام يراقب حركة مرور الشبكة ويسمح بها أو يمنعها وفق قواعد محددة مسبقًا:
أ جدار الحماية ب VPN ج DMZ د الشهادة الرقمية

2. أنسب تقنية لموظف يتصل بشبكة الشركة من مقهى عبر Wi-Fi عامة:
أ DMZ ب VPN ج مكافحة الفيروسات د نسخة احتياطية

3. خادم البريد الإلكتروني المعرّض للإنترنت يُفضل وضعه في:
أ الشبكة الداخلية ب جهاز الموظف
ج المنطقة المعزولة DMZ د خادم قاعدة البيانات

4. تثبيت برنامج مكافحة الفيروسات وتحديث نظام التشغيل ينتمي إلى طبقة:
أ مدخل الشبكة ب مسار الاتصال ج وضع الخوادم د الأجهزة الطرفية

5. السبب في أن حماية المحيط الأمني وحدها لم تعد كافية:
أ زيادة سرعة الإنترنت ب انتشار الخدمات السحابية والعمل عن بُعد
ج رخص أجهزة الكمبيوتر د كثرة برامج مكافحة الفيروسات

ثانيًا: ضع علامة (✓) أو علامة (✗)

5 درجات

6. قد يوجد جدار الحماية عند حدود الشبكة أو بين أجزائها أو على جهاز مضيف. ( )
7. نهج انعدام الثقة يكتفي بالتحقق من المستخدمين القادمين من خارج الشبكة فقط. ( )
8. تقلل DMZ احتمال وصول الهجوم إلى الشبكة الداخلية إذا اخترق خادم عام. ( )
9. الدفاع في العمق يعني الاعتماد على جدار حماية واحد قوي. ( )
10. من استخدامات VPN ربط مكاتب الشركة في مواقع مختلفة بأمان. ( )

ثالثًا: أكمل العبارات التالية

4 درجات

11. تستخدم الشبكة الافتراضية الخاصة عادةً التشفير وتقنيات ..... لحماية البيانات.
12. في نهج انعدام الثقة تُفحص ..... و ..... و ..... عند طلب الوصول.
13. تشفير الاتصال باستخدام VPN ينتمي إلى طبقة .....
14. الحدود التقليدية التي تفترض أن "الداخل آمن" تُسمى .....

رابعًا: أجب عما يأتي

6 درجات (3 لكل سؤال)

15. علّل: وضع خادم ويب عام في المنطقة المعزولة (DMZ) أكثر أمانًا من وضعه داخل الشبكة الداخلية.

16. قارن بين الأمان التقليدي ونهج انعدام الثقة من حيث: الفكرة، ووسيلة الحماية، ومنح الثقة.

2-3 الاستجابة للحوادث وإدارة المخاطر

حتى مع استخدام تقنيات الحماية والدفاع في العمق، قد يقع حادث أمني؛ لذلك ينتقل هذا الدرس من **الوقاية** إلى **الاستجابة وإدارة المخاطر**. حتى النظام المحمي جيدًا قد يتعرض لحادث أمني، مثل تسرب بيانات أو التلاعب بالملفات أو تعطل خدمة. لذلك تستخدم المؤسسات خطة منظمة لوقف انتشار المشكلة، وإزالة التهديد، واستعادة الخدمة، ثم التعلم من الحادث وتحسين الحماية. كما تُقيِّم المخاطر لتحديد أولويات المعالجة، لأن الفريق لا يستطيع معالجة كل المخاطر في الوقت نفسه.

❓ السؤال الرئيسي

عندما يقع حادث أمني، كيف ينبغي للمؤسسة أن تنظّم استجابتها عبر مراحلها العامة — وكيف تقرر أي المخاطر تعالجها أولًا؟

1. ماهية الحادث الأمني

الحادث الأمني: حدث يؤثر في **سرية** المعلومات أو **سلامتها** أو **توافرها**، أو يهددها بجدية، أو يخالف سياسة أمنية.

أمثلة نموذجية على الحوادث الأمنية

النوع	الوصف	ما يتأثر
تسرب المعلومات	تسرب المعلومات الشخصية أو السرية إلى الخارج	السرية
التلاعب بالبيانات	تعديل البيانات داخل نظام ما دون تصريح	السلامة
انقطاع الخدمة	تصبح الخدمة غير متاحة بسبب هجمات على الخادم، إلخ.	التوافر

⚠ تذكّر: ثلاثية أمن المعلومات

السرية	السلامة	التوافر
لا يطّلع على المعلومات إلا المصرح لهم	المعلومات صحيحة ولم يتم تعديلها دون تصريح	الخدمة والمعلومات متاحة عند الحاجة

⚠ انتبه

"تم إجراء تحديث للبرنامج لإضافة ميزات جديدة" ← **ليس حادثًا أمنيًا**؛ لأنه لا يؤثر في السرية أو السلامة أو التوافر ولا يخالف سياسة أمنية. أما تشفير البيانات بسبب برنامج فدية، أو تسرب معلومات العملاء، أو تعطل خدمة ويب بسبب هجوم ← فكلها حوادث أمنية.

🗺 خريطة الدرس

تمثل مراحل الاستجابة الست تسلسلًا عامًا يساعد على تنظيم الاستجابة، مع إمكانية تداخل بعض الأنشطة أو العودة إلى مراحل سابقة بحسب الحادث، ويحدد تقييم المخاطر الأولويات بناءً على **التأثير × الاحتمالية**.

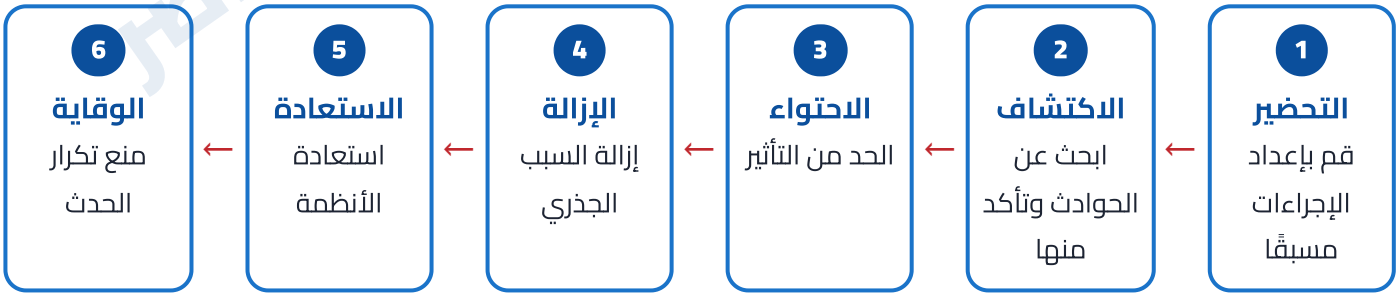
المفاهيم الأساسية: الحادث الأمني ▪ المراحل الست ▪ الاحتواء / الاستئصال ▪ المخاطرة = التأثير × الاحتمالية

2. تدفق الاستجابة للحوادث

يعرض هذا الدرس نموذجًا تعليميًا مبسطًا للاستجابة للحوادث من **ست مراحل**:

المرحلة	الوصف
① **التحضير**	إنشاء إجراءات وهياكل استجابة مسبقًا، استعدادًا للحوادث
② **الاكتشاف**	اكتشاف وتأكيد وقوع حادث
③ **الاحتواء**	تحديد نطاق التأثير بحيث لا ينتشر الضرر أكثر (اعزل الجزء المتأثر أو قيّد أثره)
④ **إزالة التهديد (الاستئصال)**	إزالة التهديد ومسبباته، مثل حذف البرمجيات الخبيثة ومعالجة الثغرة المستغلة
⑤ **الاستعادة**	إعادة الأنظمة والخدمات إلى حالة تشغيل آمنة وطبيعية (قد تشمل الاستعادة من نسخة احتياطية سليمة)
⑥ **الدروس المستفادة والتحسين**	تحليل ما حدث، وتوثيق الدروس، وتحسين الضوابط لتقليل احتمال التكرار وأثره

الاستجابة للحوادث: 6 مراحل (الشكل 2.3.1)



يساعد ترتيب المراحل على فهم التسلسل العام، لكن الاستجابة الفعلية **قد تتضمن تداخلًا أو تكرارًا** بين بعض الأنشطة. فمثلًا، قد يكشف الاسترداد عن بقايا للتهديد تستلزم العودة إلى الاحتواء أو إزالة التهديد.

💭 **توقف وفكّر: لماذا يجب أن يأتي الاحتواء قبل الاستئصال؟**

✓ لأن الأولوية هي إيقاف انتشار الضرر فورًا (مثل فصل الجهاز المصاب عن الشبكة)؛ فلو بدأنا بالبحث عن السبب وإزالته والتهديد ما زال ينتشر، ستُصاب أجهزة وبيانات أكثر ويكبر الضرر.

⚠ **ماذا يحدث إذا بدأت الاستعادة قبل إزالة السبب؟**

قد تبقى البرمجية الخبيثة أو الثغرة المستغلة، فيعود الهجوم مرة أخرى، ويلزم الرجوع إلى **الاحتواء وإزالة التهديد**.

🧠 **طريقة سهلة لحفظ الترتيب: "جهّز ← اكتشف ← احصر ← اقتلع ← رجّع ← اتعلّم"**

جهّز (التحضير) ← **اكتشف** (الاكتشاف) ← **احصر** الضرر (الاحتواء) ← **اقتلع** السبب (الاستئصال) ← **رجّع** الأنظمة (الاستعادة) ← **اتعلّم** وحسّن (الدروس المستفادة والتحسين).

3. مفهوم تقييم المخاطر

الخطر: احتمال أن يقع حدث يسبب ضررًا، مع مراعاة احتمال وقوعه وحجم أثره.

في هذا الدرس نستخدم طريقة مبسطة لتقدير درجة الخطر اعتمادًا على عاملين:

درجة الخطر = درجة التأثير × درجة الاحتمالية

① التأثير
حجم الضرر إذا وقع الحدث.

② الاحتمالية
مدى احتمال وقوع الحدث.

مصفوفة تقييم المخاطر (الشكل 2.3.2)

التأثير ↓ / الاحتمالية ←	منخفض	متوسط	مرتفع
مرتفع	متوسط	مرتفع	**مرتفع جدًا**
متوسط	منخفض	متوسط	مرتفع
منخفض	منخفض جدًا	منخفض	متوسط

يجب معالجة المخاطر ذات التأثير المرتفع والاحتمالية المرتفعة أولًا.

تُعد المخاطر ذات التأثير العالي والاحتمالية العالية من أعلى الأولويات في هذا النموذج المبسط. أما ترتيب الحالات الأخرى فيعتمد على درجات المصفوفة والسياق والضوابط المتاحة.

مثال تطبيقي على ترتيب الأولويات

الحالة	التأثير	الاحتمالية	الدرجة من المصفوفة	الأولوية
أ	كبير	عالية	مرتفع جدًا	**الأولى**
ب	صغير	عالية	متوسط	**متساويتان — يُحسم الترتيب بالسياق والضوابط المتاحة**
ج	كبير	منخفضة	متوسط	
د	صغير	منخفضة	منخفض جدًا	**الأخيرة**

⭐ الفكرة الرئيسة

تعامل مع الحوادث وفق التسلسل العام — **احتوِ، ثم أزل السبب، ثم استعد، ثم استخلص الدروس المستفادة وحسّن الضوابط** لتقليل احتمال التكرار — وحدد أولويات المخاطر بناءً على **التأثير × الاحتمالية**، بحيث يظل الضرر صغيرًا ولا تتكرر المشكلات.

❓ لماذا نحتاج إلى تقييم المخاطر أصلًا؟

لأن فريق الأمان لا يستطيع معالجة كل المخاطر في الوقت نفسه؛ فالموارد (الوقت والأفراد والميزانية) محدودة. لذلك نرتّب المخاطر بحسب **التأثير × الاحتمالية** ونبدأ بالأعلى أولوية، بهدف تقليل الضرر واحتمال تكرار المشكلة.

مصطلحات أساسية للدرس 2-3

الحادث الأمني
حدث يؤثر في سرية المعلومات أو سلامتها أو توافرها، أو يهددها بجدية، أو يخالف سياسة أمنية.

الاحتواء
الحد من انتشار الضرر.

الاستئصال
إزالة السبب (التهديد ومسبباته).

الاستعادة
إعادة الأنظمة والخدمات إلى حالة تشغيل آمنة وطبيعية.

التأثير
مقدار الضرر إذا وقعت المخاطرة.

الاحتمالية
مدى احتمالية وقوع المخاطرة.

✎ مثال محلول

(1) ضع علامة (○) أمام العبارة الصحيحة وعلامة (×) أمام العبارة الخاطئة:

العبارة	الحكم	التعليل
أ. الحادث الأمني حدث يؤثر في سرية المعلومات أو سلامتها أو توافرها، أو يهددها بجدية، أو يخالف سياسة أمنية.	○	تعريف صحيح للحادث الأمني.
ب. في الاستجابة للحوادث، من المهم أولًا منع انتشار الضرر قبل إزالة السبب.	○	يُجرى الاحتواء قبل الاستئصال.
ج. يمكن تحديد حجم المخاطرة بالتأثير وحده.	×	يُحدَّد بكل من التأثير والاحتمالية معًا.
د. المرحلة الأخيرة من الاستجابة للحوادث هي الدروس المستفادة والتحسين.	○	هي المرحلة السادسة والأخيرة.

(2) لكل إجراء، بيّن أي مرحلة من مراحل الاستجابة ينتمي إليها:

الإجراء	المرحلة
أ. إنشاء إجراءات استجابة مسبقًا، استعدادًا للحوادث	**التحضير**
ب. فصل حاسوب مصاب بالبرمجيات الخبيثة عن الشبكة	**الاحتواء**
ج. إزالة إصابة البرمجيات الخبيثة	**الاستئصال**
د. تحليل السبب واتخاذ التدابير اللازمة لضمان عدم تكرار الحادث نفسه	**الدروس المستفادة والتحسين**

سؤال بنمط الامتحان [6 درجات]

اشرح أهمية التسلسل العام لمراحل الاستجابة للحوادث، مستخدمًا الاحتواء والاستئصال والاستعادة كمثال، ووضّح لماذا قد تحتاج الاستجابة الفعلية إلى العودة إلى مرحلة سابقة.

✓ التسلسل ينظّم الاستجابة: **الاحتواء** أولًا لوقف انتشار الضرر، ثم **الاستئصال** لإزالة السبب (البرمجية الخبيثة والثغرة)، ثم **الاستعادة** لإعادة الأنظمة لحالة آمنة. فإذا بدأت الاستعادة قبل إزالة السبب قد تبقى البرمجية أو الثغرة ويعود الهجوم. وقد تحتاج الاستجابة الفعلية للعودة لمرحلة سابقة إذا اكتُشفت أثناء الاستعادة بقايا للتهديد، فنرجع إلى الاحتواء أو الإزالة.

تدريبات وتمارين الدرس 2-3 (مع الإجابات النموذجية)

1. ما المصطلح الذي يُطلق على حدث يؤثر في سرية المعلومات أو سلامتها أو توافرها، أو يهددها بجدية؟

✓ الحادث الأمني.

2. اذكر المراحل الست للاستجابة للحوادث حسب تسلسلها العام.

✓ التحضير ← الاكتشاف ← الاحتواء ← إزالة التهديد (الاستئصال) ← الاستعادة ← الدروس المستفادة والتحسين.

3. ما العاملان المستخدمان لتحديد حجم المخاطرة؟

✓ التأثير والاحتمالية (درجة الخطر = التأثير × الاحتمالية).

4. اختر الخيار الذي لا يمثل مثالًا مناسبًا لحادث أمني:

أ تشفير البيانات بسبب برنامج فدية
ب تسرب معلومات العملاء إلى الخارج
ج تحديث البرنامج لإضافة ميزات جديدة
د تعطل خدمة ويب بسبب هجوم على الخادم

✓ الإجابة (ج).

5. اختر الخيار الذي يصف مفهوم تقييم المخاطر بأنسب طريقة:

أ يكفي معالجة المخاطر ذات التأثير الكبير فقط
ب يكفي معالجة المخاطر ذات الاحتمالية العالية فقط
ج ينبغي معالجة المخاطر ذات التأثير العالي والاحتمالية العالية أولًا
د يجب معالجة جميع المخاطر في آن واحد

✓ الإجابة (ج).

6. املأ الفراغات: يُسمى الحدث الذي يؤثر في سرية المعلومات أو سلامتها أو توافرها (أ). وفي نموذج الدرس يُستخدم (ب) للحد من انتشار الضرر، ثم تُنفّذ (ج) لإزالة التهديد ومسبباته، وتليها (د) لإعادة الأنظمة والخدمات، ثم تأتي (هـ) لتحليل ما حدث وتحسين الحماية.

✓ (أ) الحادث الأمني ▪ (ب) الاحتواء ▪ (ج) إزالة التهديد (الاستئصال) ▪ (د) الاستعادة ▪ (هـ) الدروس المستفادة والتحسين

7. اختر الوصف الأدق للتسلسل العام في نموذج الاستجابة للحوادث:

أ الاكتشاف ← الاستئصال ← الاحتواء ← الاستعادة
ب التحضير ← الاكتشاف ← الاحتواء ← الاستئصال ← الاستعادة ← الدروس المستفادة والتحسين
ج الاكتشاف ← الاستعادة ← الاحتواء ← الدروس المستفادة والتحسين
د الاحتواء ← الاكتشاف ← الاستئصال ← التحضير

✓ الإجابة (ب).

⚙ فكّر كمهندس — هجوم فدية على مدرسة (الملفات مشفرة والموظفون محظورون)

المراحل المتبقية: الاحتواء (فصل الأجهزة المصابة) ← الاستئصال (إزالة البرنامج وسد الثغرة) ← الاستعادة (من نسخة احتياطية سليمة) ← الدروس المستفادة. **الأولوية:** هجوم الفدية (تأثير كبير واحتمالية عالية حاليًا) قبل انقطاع الكهرباء القصير. **الاختيار الصحيح:** اتباع المراحل بالترتيب، وليس الاستعادة فورًا؛ لأن الاستعادة قبل إزالة التهديد قد تعيد الإصابة.

امتحان الدرس 3-2: الاستجابة للحوادث وإدارة المخاطر

20 درجة

الاسم: ..... الفصل: ..... الزمن: 30 دقيقة الدرجة: ..... / 20

أولًا: اختر الإجابة الصحيحة

5 درجات

1. تعطل خدمة ويب بسبب هجوم على الخادم يؤثر أساسًا في:

أ السرية ب السلامة ج التوافر د عدم التنصل

2. المرحلة الأولى في نموذج الاستجابة للحوادث:

أ الاكتشاف ب التحضير ج الاحتواء د الاستعادة

3. حذف البرمجيات الخبيثة ومعالجة الثغرة المستغلة يتم في مرحلة:

أ الاحتواء ب الاكتشاف

ج إزالة التهديد (الاستئصال) د التحضير

4. خطر تأثيره منخفض واحتماليته منخفضة، درجته في المصفوفة:

أ منخفض جدًا ب منخفض ج متوسط د مرتفع

5. إعادة الأنظمة من نسخة احتياطية سليمة تتم في مرحلة:

أ الاحتواء ب الاستعادة ج التحضير د الاكتشاف

ثانيًا: ضع علامة (✓) أو علامة (✗)

5 درجات

6. تعديل البيانات داخل نظام ما دون تصريح يُعد حادثًا أمنيًا. ( )
7. لا يمكن أبدًا العودة إلى مرحلة سابقة أثناء الاستجابة للحوادث. ( )
8. درجة الخطر = درجة التأثير + درجة الاحتمالية. ( )
9. تُعالج المخاطر ذات التأثير العالي والاحتمالية العالية أولًا. ( )
10. مرحلة الاكتشاف تعني اكتشاف وتأكيد وقوع حادث. ( )

ثالثًا: أكمل العبارات التالية

4 درجات

11. ..... هو حجم الضرر إذا وقع الحدث.
12. ..... هي مدى احتمال وقوع الحدث.
13. المرحلة التي تهدف إلى تقليل احتمال تكرار الحادث وأثره هي .....
14. خطر تأثيره مرتفع واحتماليته متوسطة، درجته في المصفوفة .....

رابعًا: أجب عما يأتي

6 درجات (3 لكل سؤال)

15. رتّب المراحل التالية حسب التسلسل العام، ثم بيّن الغرض من مرحلة الاحتواء: (الاستعادة – الاحتواء – التحضير – الدروس المستفادة والتحسين – الاكتشاف – الاستئصال)

16. اكتشف متجر إلكتروني أن بيانات العملاء قد تسرّبت: حدّد المرحلتين التاليتين اللتين يجب تنفيذهما وسبب ذلك، وحدّد خطرًا ينبغي إعطاؤه الأولوية.

اختبار شامل على الوحدة الثانية

أولًا: اختر الإجابة الصحيحة

1. يُستخدم أثناء مصافحة TLS للمصادقة والاتفاق على مفاتيح الجلسة:

أ التشفير المتماثل
ب التشفير بالمفتاح العام
ج جدار الحماية
د المنطقة المعزولة

2. التقنية التي تكتشف التلاعب وتوفر دليلًا يدعم عدم التنصل:

أ التوقيع الرقمي
ب VPN
ج التشفير المتماثل
د 2FA

3. بطاقة دخول + بصمة إصبع تمثل:

أ المعرفة + الحيازة
ب الحيازة + السمات الحيوية
ج المعرفة + السمات الحيوية
د المعرفة + المعرفة

4. ربط مكاتب الشركة في مواقع مختلفة بأمان يتم عبر:

أ DMZ
ب مكافحة الفيروسات
ج VPN
د الشهادة الرقمية

5. تثبيت برنامج مكافحة الفيروسات ينتمي إلى طبقة:

أ مدخل الشبكة
ب مسار الاتصال
ج وضع الخوادم
د الأجهزة الطرفية

6. فصل حاسوب مصاب عن الشبكة يمثل مرحلة:

أ الاكتشاف
ب الاحتواء
ج الاستعادة
د التحضير

7. خطر تأثيره متوسط واحتماليته مرتفعة، درجته في المصفوفة:

أ منخفض
ب متوسط
ج مرتفع
د مرتفع جدًا

ثانيًا: صحّح ما تحته خط

8. يحمي TLS بيانات الجلسة باستخدام التشفير بالمفتاح العام.

9. تُوضع خوادم الويب والبريد المعرّضة للإنترنت داخل الشبكة الداخلية.

10. نهج انعدام الثقة يمنح الثقة تلقائيًا لمن هو داخل الشبكة.

11. يُحدَّد حجم المخاطرة بـ التأثير وحده.

ثالثًا: أجب عما يأتي

12. علّل: كلمة مرور + سؤال سري ليست مصادقة ثنائية.

13. علّل: الأمان التقليدي القائم على المحيط الأمني وحده لم يعد كافيًا.

14. قارن بين التشفير المتماثل والتشفير بالمفتاح العام من حيث الوظيفة في TLS والسرعة.

15. اذكر ثلاثة أمثلة لحوادث أمنية، وحدد ما يتأثر في كل منها (السرية / السلامة / التوافر).

خلاصة الوحدة في صفحة

الدرس	تذكّر
2-1 التشفير والمصادقة	تستخدم مصافحة HTTPS آليات المفتاح العام للمصادقة والاتفاق الآمن على أسرار مشتركة تُشتق منها مفاتيح الجلسة، ثم تُحمى بيانات الجلسة بالتشفير المتماثل بسرعة. تحافظ الخدمات على أمانها من خلال تكديس التشفير والشهادات والتوقيعات والمصادقة الثنائية (2FA).
2-2 أمان الشبكات	كدّس دفاعاتك — جدار الحماية، والشبكة الافتراضية الخاصة، والمنطقة المعزولة، والأجهزة الطرفية — وتحقق من كل عملية وصول (نهج انعدام الثقة). عندها يصبح من غير المرجح أن يؤدي خرق واحد إلى كشف الشبكة بأكملها.
2-3 الحوادث والمخاطر	اتبع التسلسل العام للمراحل الست (تحضير ← اكتشاف ← احتواء ← استئصال ← استعادة ← الدروس المستفادة والتحسين) مع إمكانية التداخل أو العودة لمرحلة سابقة، وحدد أولويات المخاطر بناءً على التأثير × الاحتمالية.

✅ قائمة مراجعة قبل الامتحان

- ☐ أستطيع شرح مراحل اتصال HTTPS الثلاث وآلية الحماية في كل مرحلة.
- ☐ أفرّق بين التشفير المتماثل والتشفير بالمفتاح العام ودور كل منهما في TLS.
- ☐ أميّز بين التشفير والتوقيع الرقمي والشهادة الرقمية والمصادقة الثنائية.
- ☐ أصنّف عوامل المصادقة (المعرفة – الحيازة – السمات الحيوية) وأعرف متى تكون المصادقة ثنائية.
- ☐ أشرح أدوار جدار الحماية وVPN وDMZ وطبقات الدفاع في العمق الأربع.
- ☐ أقارن بين الأمان التقليدي ونهج انعدام الثقة.
- ☐ أرتّب مراحل الاستجابة للحوادث الست وأعرف لماذا يأتي الاحتواء قبل الاستئصال.
- ☐ أستخدم مصفوفة المخاطر (التأثير × الاحتمالية) لترتيب الأولويات.

مع تمنياتي لكم بالتفوق والنجاح

المهندس / أحمد عبد الناصر

01017865860